Information Security Introduction



Viruses, Bots, and Phish, Oh My!



What is Information Security?

Why is it Important?

What Can We Do?

Viruses, Bots, and Phish, Oh My!

What Is Information Security?

Deals with several different "trust" aspects of information and its protection

The U.S. Government's Committee on National Security Systems defines **INFOSEC** as:

> "The protection of information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability." (CNSS, 2010)

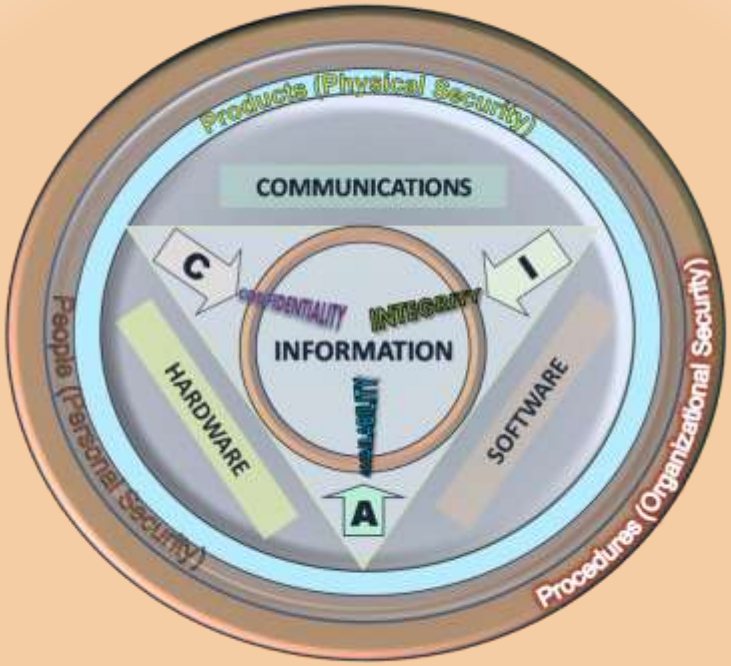
Viruses, Bots, and Phish, Oh My!

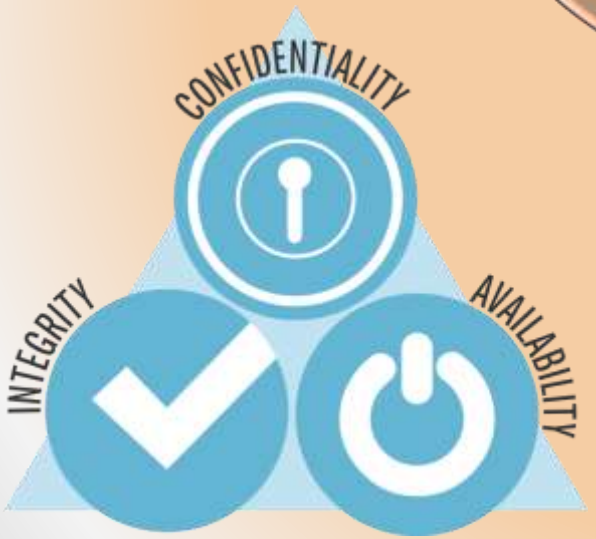
What Is Information Security?

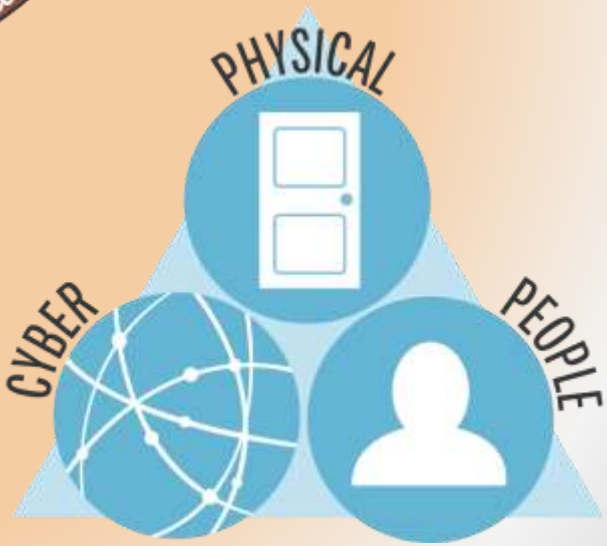
Three widely accepted elements or areas of focus (referred to as the "CIA Triad"):

- Confidentiality
- Integrity
- Availability (Recoverability)

Includes Physical Security as well as Electronic


Products (Physical Security)
COMMUNICATIONS
C
I
CONFIDENTIALITY
INTEGRITY
INFORMATION
AUTHENTICITY
A
HARDWARE
SOFTWARE
People (Personnel Security)
Procedures (Organizational Security)


CONFIDENTIALITY
INTEGRITY
AVAILABILITY


PHYSICAL
CYBER
PEOPLE

Definitions

Malware:

- Hostile, intrusive, or annoying software or program code ("malicious" + "software“)
- Includes computer viruses, worms, trojan horses, bots, spyware, adware, etc
- Software is considered malware based on the intent of the creator rather than any particular features

Definitions

Internet bot:

- also known as **web robots**, are automated internet applications controlled by software agents
- These bots interact with network services intended for people, carrying out monotonous tasks and behaving in a humanlike manner (i.e., computer game bot)
- Bots can gather information, reply to queries, provide entertainment, and serve commercial purposes.
- Botnet - a network of "zombie" computers used to do automated tasks such as spamming or reversing spamming

Definitions

Adware:

Advertising-supported software is any software package which automatically plays, displays, or downloads advertising material to a computer after the software is installed on it or while the application is being used.

Adware is software integrated into or bundled with a program, typically as a way to recover programming development costs through advertising income

Definitions

Spyware:

A broad category of software designed to intercept or take partial control of a computer's operation without the informed consent of that machine's owner or legitimate user

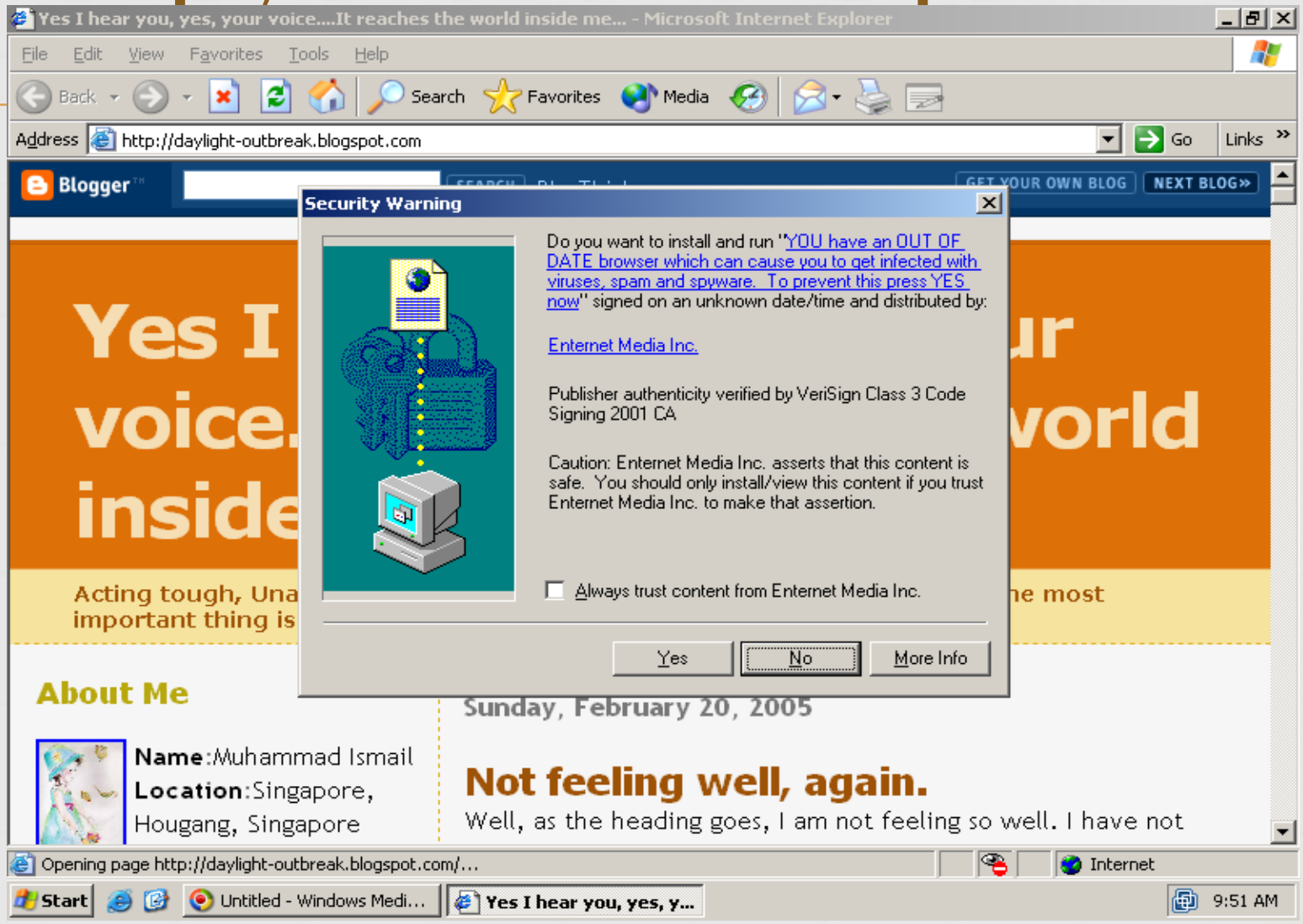
In simpler terms, spyware is a type of program that watches what users do with their computer and then sends that information over the internet

Definitions

Spyware:

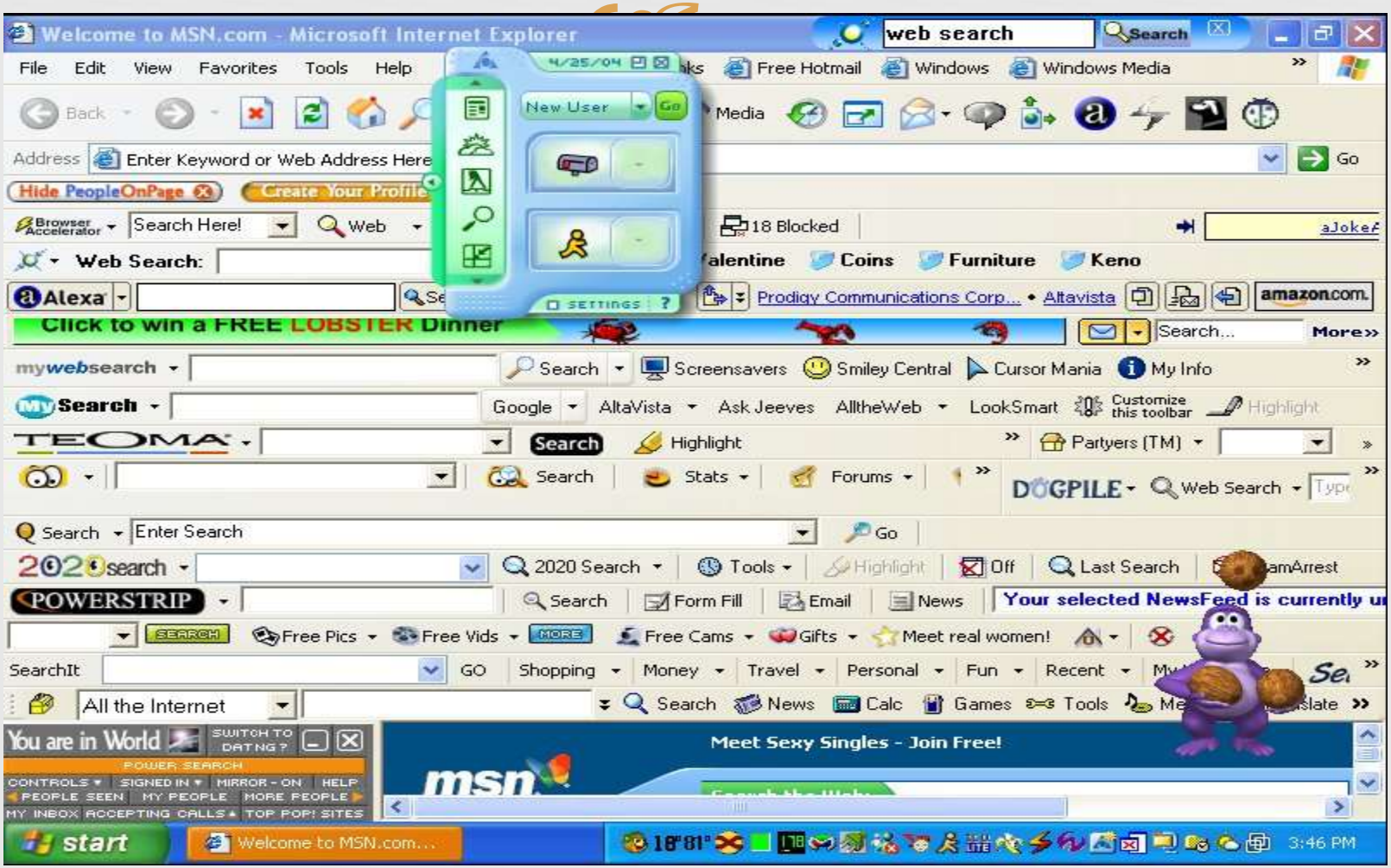
- Spyware can collect many different types of information about a user:
  - Records the types of websites a user visits
  - Records what is typed by the user to intercept passwords or credit card numbers
  - Used to launch "pop up" advertisements
- Many legitimate companies incorporate forms of spyware into their software for purposes of advertisement(Adware)

Spyware Example



Spyware Example

(add-on toolbars)



Definitions

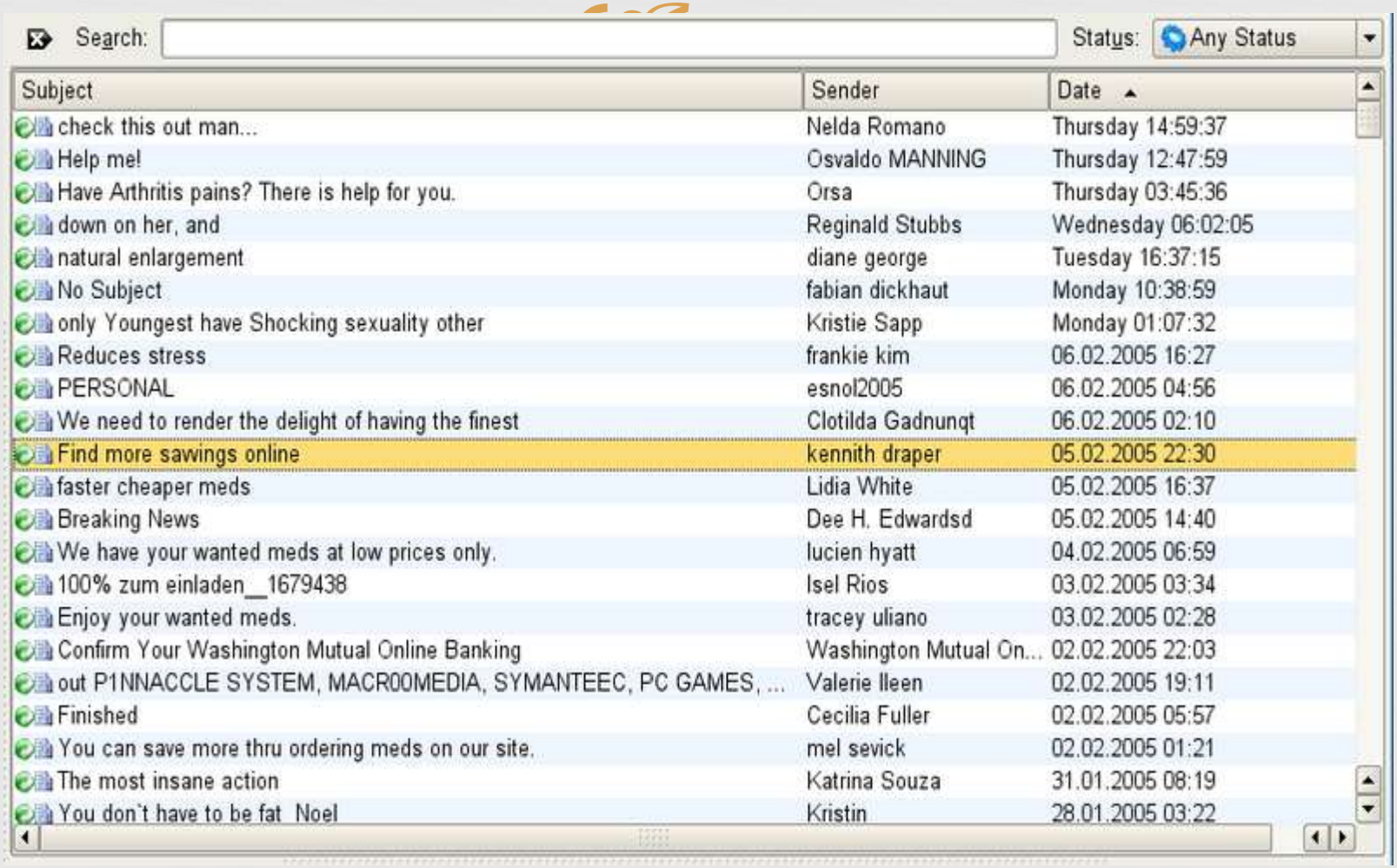
Spam:

Spamming is the abuse of electronic messaging systems to send unsolicited, undesired bulk messages

Spam media includes:

- e-mail spam (most widely recognized form)
- instant messaging spam
- Usenet newsgroup spam
- Web search engine spam
- spam in blogs
- mobile phone messaging spam

Spam Example



Definitions

Phishing:

A criminal activity using social engineering techniques.

An attempt to acquire sensitive data, such as passwords and credit card details, by masquerading as a trustworthy person or business in an electronic communication.

Typically carried out using email or an instant message

Phishing Example



Dear valued customer of TrustedBank,

We have recieved notice that you have recently attempted to withdraw the following amount from your checking account while in another country: $135.25.

If this information is not correct, someone unknown may have access to your account. As a safety measure, please visit our website via the link below to verify your personal information:

http://www.trustedbank.com/general/custverifyinfo.asp

Points to "bad" IP Address!

Once you have done this, our fraud department will work to resolve this discrepency. We are happy you have chosen us to do business with.

Thank you,
TrustedBank

Member FDIC © 2005 TrustedBank, Inc.

Ransomware


INDUSTRIES IN NORTH AMERICA REPORTING RANSOM ATTACKS IN THE LAST YEAR
Government organizations
15.4%
Manufacturing
13.9%
Construction
13.2%
Utilities
11.1%
Professional services
10.4%
Retail
7.5%
Real estate
7.1%
Hospitality
6.1%
Healthcare
5.7%
Education
5%
Financial institutions
4.6%
Percentage of all reported incidents caused by ransomware


HOW MANY ORGANIZATIONS REPORTED RANSOM ATTACKS IN THE LAST YEAR?
Saudi Arabia 88%
Turkey 74%
China 69%
Spain 66%
South Africa 66%
Mexico 61%
Italy 58%
UK 57%
US 54%
Germany 51%
Canada 46%
France 44%
Australia 40%
Japan 38%
SafetyDetectives


Data recovery after the attack
99%
of those whose data was encrypted got some data back.
#1
method used to restore encrypted data was backups
46%
paid the ransom to get data back.
61%
of encrypted data was restored, on average, after paying the ransom.
4%
that paid the ransom got all their data back.

Definitions

Keystroke Logging:

- Keystroke logging (often called keylogging) is a diagnostic used in software development that captures the user's keystrokes
  - Useful to determine sources of error in computer programs
  - Used to measure employee productivity on certain clerical tasks
- Highly useful for law enforcement and espionage
  - Obtain passwords or encryption keys and thus bypassing other security measures
- Widely available on the internet and can be used by anyone for the same purposes

Definitions

Keystroke Logging:

- Can be achieved by both hardware and software means
- Hardware key loggers are commercially available devices which come in three types:
  - Inline devices that are attached to the keyboard cable
  - Devices installed inside standard keyboards
  - Keyboards that contain the key logger already built-in
- Writing software applications for keylogging is trivial, and like any computer program can be distributed as malware (virus, trojan, etc.)

Keylogger Example

In-line hardware Keylogger



Viruses, Bots, and Phish, Oh My!

Why is it Important?

- Over the last few years, the IT security threat landscape has changed significantly.
- Traditional malware threats hit an apparent wall in 2005
- However new threats (bots, spam, phishing) have stepped into the void.
- Remember the objective - the "CIA Triad" :
  - Confidentiality
  - Integrity
  - Availability (Recoverability)

Viruses, Bots, and Phish, Oh My!

Why is it Important?

- Unauthorized access (malware, spyware) limits our ability to protect the confidentiality of the data
- Malicious programs can alter the data values, destroying the integrity of the data
- Denial of Service (DoS) attacks can shut down a server and/or network, making the system unavailable.
- Efforts to correct costs corporations time and money!

Viruses, Bots, and Phish, Oh My!

Why is it Important?

There were on average over eight million phishing attempts per day during the latter half of 2005 (Symantec)

The California legislature found that spam cost United States organizations alone more than $10 billion in 2004, including lost productivity and the additional equipment, software, and manpower needed to combat the problem.

Viruses, Bots, and Phish, Oh My!

Why is it Important?

- Regulatory Issues:
  - HIPAA (electronic personal identifiable information): Personal health information protection
  - Sarbanes-Oxley Act (federal securities law focused on data accuracy and integrity)
  - PCI Security (Payment Card Industry security measures)
- Potential/Growing Issues:
  - Liability for damage caused by bot-nets
  - Loss of corporate confidential information (financials, personnel)
  - Electronic Blackmail

Viruses, Bots, and Phish, Oh My!

What Can We Do?

- Security Assessment
  - Identify areas of risk
  - Identify potential for security breaches, collapses
  - Identify steps to mitigate
- Security Application
  - Expert knowledge (train, hire, other)
  - Multi-layered Approach (there is no single solution)
  - Policies and Procedures

Viruses, Bots, and Phish, Oh My!

What Can We Do?

- Security Awareness
  - Not just for the geeks!
  - Security Training at all levels (external and/or internal)
  - Continuing education and awareness – not a one-time shot!
  - Make it part of the culture

Viruses, Bots, and Phish, Oh My!

Key Takeaways:

Objective of InfoSec is ***Confidentiality, Integrity and Availability***…protect your systems and your data

Threats are numerous, evolving, and their impact is costly

Security should be applied in layers (“road blocks”)

Security Awareness at all levels must be maintained

Failure to Secure is an Opportunity to Fail

Refernce Material



1. *Computer Security: Art and Science*, Matthew Bishop

2. *Cryptography and Network Security* by William Stalling 6th Edition, 2012

3. *Principles of Information Security* 3rd E by Michael E. Whitman and Herbert J. Mattord

Information Security



Questions?